

Misconfigured Public Cloud Storage Access response

Cloud · **Critical** severity · SOC IR Playbook

Incident type	Cloud Misconfiguration - Public Exposure
Severity	Critical
Priority	Critical
Detection sources	CSPM Tools, Cloud Audit Logs, SIEM, Threat Intelligence, Manual Discovery, Bug Bounty Reports

Scenario

A cloud storage bucket, container or object is unintentionally made publicly accessible or exposed to unauthorised users (e.g., via public-read or authenticated users access settings). This may lead to data leakage, regulatory non-compliance or exploitation by threat actors.

MITRE ATT&CK

T1213.003, T1526, T1530

Preparation

Deploy CSPM tools Continuously scan for misconfigured storage (e.g., Wiz, Prisma Cloud orca Security)
Implement policy-as-code Use tools like AWS Config, Azure Policies or GCP Org Policies to restrict public storage
Monitor access logs Enable logging for bucket access and object-level events Enable default encryption
Automatically encrypt all objects with KMS keys Classify and tag sensitive data Apply metadata for easier DLP and access control enforcement

Detection & Analysis

Alert from CSPM or cloud platform Detection of public-read, public-write or wildcard access to storage Verify access level Confirm if the object, bucket or container is readable by anyone or broad IAM groups Check access logs Identify IPs, users or services that accessed the exposed resource Determine data sensitivity Was the data PII, financial, source code or internal documentation?

Containment

Remove public access Immediately revoke public or everyone permissions on the storage resource Apply least privilege policies Lock down access to only required IAM identities or roles Revoke temporary tokens (if abused) Disable access keys or tokens used to exploit the exposure Quarantine exposed data (optional) Move sensitive files to a restricted bucket for analysis or remediation

Eradication

Correct IAM or ACL policies Use policy templates or automation to enforce secure access controls Rotate keys or tokens If access keys, SAS tokens or signed URLs were exposed Remove unauthorised files Delete uploaded malware, backdoors or tampered content (if applicable) Disable bucket listing Prevent attackers from enumerating contents in the future

Recovery

Restore secure access Only after verifying proper permissions are in place Notify affected teams Especially data owners, app teams, compliance and legal if sensitive data was involved Resume usage After confirming no remaining exposure or misconfiguration Enable stronger logging If not already in place, ensure CloudTrail/S3/Azure Blob/GCP audit logs are active

Lessons Learned & Reporting

Conduct full exposure analysis Determine duration, access scope and data classification of exposed content Update access control templates Enforce deny-by-default posture for new storage resources Train teams on cloud

access policies Educate on secure storage deployment and data handling best practices Report if necessary
Under PDPA, GDPR, HIPAA, etc. if data breach involves personal or regulated data Integrate detection into CI/CD
Catch public access settings before production using IaC scanning (e.g., Checkov, tfsec)

Tools typically involved

CSPM (e.g., Wiz, Prisma Cloud orca); Cloud-native tools (e.g., AWS S3 Access Analyzer, Azure Defender, GCP Security Command Center); SIEM (e.g., Sentinel, Splunk); DLP tools (e.g., Microsoft Purview, Google DLP); IAM policy analyzers (e.g., PMapper, CloudSploit); Threat Intel feeds for leaked buckets/domains

Success metrics (SLA targets)

Detection Time <5 minutes from misconfiguration Public Access Removal Time <15 minutes from alert Exposure Impact Report Within 24 hours IAM Policy Audit Completion 100% of affected projects or buckets within 48 hours Compliance Review Completion Within 72 hours (or regulatory deadline)